Udyvia: Privacy note

What this covers. How Udyvia handles an owner's data from sign-up to order tracking, and what the sales back-office can see. Every statement matches behaviour in the code and is tested (`backend/tests/test_privacy.py`, `test_accounts.py`). It describes design choices; it is not legal advice.

What we collect, why, and for how long

Data	Why we need it	Kept for
Account: name, email, mobile, password (stored only as a salted scrypt hash)	To sign in and resume later	Until the owner deletes the account (one tap, erases everything below too)
Business type, headcount, locations, city, GST yes/no, needs, chosen add-ons, KYC decision (PASS etc.)	To recommend a bundle, price it, and resume where the owner stopped	Saved to the account; reset after 90 days of inactivity. The working copy in memory goes after 24 hours (72 for a quote)
Consent to be called (yes/no, with date)	So sales calls only people who agreed	Until changed or the account is deleted
GSTIN, only if the owner types it	To unlock GST-only products	24 hours in memory only. Never saved to the account
Four KYC documents (images) and the fields read from them	To verify the business against the GST and Udyam registers	24 hours, or until the owner withdraws
Signatory name (e-sign) and, optionally, a phone number	To record the agreement; to send order updates	Order record (saved to the account so tracking survives a restart): 30 days in this demo. Phone on the order: last 4 digits only

We do not collect location, contacts or anything else. Sign-in uses an httpOnly cookie (the page's scripts cannot read it) that expires after 7 days; only a hash of it is stored. The browser keeps nothing else between visits.

Consent and control

- **Before any upload** the owner sees a notice with the purpose, the data used, the retention period and how to withdraw. Uploads are refused without it.
- **Withdraw at any time** with one tap: uploads and results are deleted immediately.
- **Automatic deletion.** A job runs every 10 minutes and deletes anything past its retention period, whether or not anyone is using the service. Files left by a restart are swept on startup and every run.

Where data goes

- **Documents never leave our server.** They are read with local OCR and checked against the registers. No document image or OCR text is sent to any AI service.
- **The chat uses an AI model (Gemini)** only to turn free text into fields and to phrase the explanation. Before sending, GSTIN, Udyam, phone, email and 12-digit ID numbers are replaced with placeholders. Prices, eligibility and KYC decisions are always computed by our rules, never by the model.
- **Voice (Azure AI Speech)** reads the advisor's replies aloud, only when the owner taps Listen or turns on read-aloud. It receives the reply text only, with identifiers replaced by placeholders. The owner's own messages and documents stay out; we log only request length.

Back-office (sales and partners)

- **Staff accounts only.** Every list view is audit-logged as a count, never as names.
- **Only people who agreed to be called are listed.** Anyone who declined is counted, never shown.
- **The call-priority score** is a small model trained on 5,000 historical leads. It uses how far the lead got, business type, city tier, team size, locations, GSTIN yes/no and current internet. It never sees documents, OCR text or KYC findings, and it only orders a call list: a person decides who to call. It is modestly better than chance within a stage, and the screen says so.

Masking, logs and safeguards

- Identifiers are masked on screen (for example `32•••••••••T1ZW`) and in every API response. A filter scrubs all application and server logs. The audit trail holds events, ids, counts and decisions only, never names, numbers, document content or chat text.
- Session and order ids are random; an order that belongs to an account is visible only to that account. Five wrong passwords lock sign-in for 10 minutes, and the error never reveals whether an email has an account. Uploads (PNG or JPEG under 8 MB) sit in an owner-only folder under server-chosen names.

Limits of this prototype, and what production needs

Working data is held in memory, accounts and progress sit in a local SQLite file, and the GST, Udyam, e-sign and payment services are mocks. Production needs: email or OTP verification at sign-up, encrypted managed storage in India, written agreements with every processor, a breach-response process and a named grievance contact. Use an AI tier that does not train on inputs.